

(e.g., what happens as a result of removing power from a system or system component). Tests may focus on backup and recovery options of systems. The degree of testing can vary, from individual system components up to comprehensive tests of all system components that support business operations. Effectively, the distinction between the two is that exercises address people, processes, and systems whereas tests address specific aspects of a system.

VII.A Exercise and Test Program

Management should develop a comprehensive exercise and testing program including objectives, and plans to validate the entity's ability to restore critical business functions. The entity's risk profile should influence the frequency, objectives, and documentation of the overall exercise schedule. The entity's consolidated exercise and test schedule should be reflective of exercise and test objectives and the overall exercise and test universe.³⁹

Management should designate personnel with the authority to control the exercise or test and confirm milestones are met. Business line management should retain ownership and accountability for testing resilience of business operations, including applications and processes (both internal and external). While business line management should be responsible for testing its specific business processes and related interdependencies, managers should coordinate with personnel involved in the enterprise-wide business continuity process and support areas, such as IT and facilities management. Results should be reported to the board and senior management for inclusion in the enterprise-wide business continuity process.

Exercises and tests should occur either at appropriate intervals, when new risks are identified, or when significant changes affect the entity's operating environment. Significant changes can render existing test plans obsolete, so BCP(s) should be retested soon after the change. A comprehensive program allows management to evaluate business interdependencies and improve continuity and resilience.

A key objective for management should be to develop a testing process that validates the effectiveness of the entity's business continuity program, and identifies any deficiencies that may exist. Therefore, the exercise and test program should incorporate the following:

- A policy that includes strategies and expectations for exercise and test planning.
- Roles and responsibilities for implementation.
- Sufficient personnel to perform the exercise or test, provide oversight, and document the results.
- Precautions to safeguard production data, such as performing a backup before performing a test in a test environment, or testing during non-peak hours.
- Provisions for emergency stops (i.e., management's authority to stop an exercise if a real-life event occurs) and concluding exercises and tests.

³⁹ Similar to an audit universe, an entity's exercise and test universe is composed of an inventory of all business processes and system components that are compiled and maintained to identify areas for the exercise and test planning process.

- Verification of continuity and resilience process assumptions and the ability to process a sufficient volume of work during adverse operating conditions.
- Activities commensurate with the importance of the business process, as well as to critical financial markets.
- Result comparison against the BCP to identify gaps between the exercise or test process and recovery guidelines, with revisions incorporated where appropriate.
- Independent review of business continuity program and exercises and tests (internal and external).

VII.B Exercise and Test Policy

The entity's policies should define exercise and testing expectations and strategies. The policies should:

- Identify key roles and responsibilities.
- Establish minimum frequency, scope, and reporting requirements.
- Define documentation expectations that are consistent across business processes.
- Include a process for correcting deficiencies identified during exercises or tests.
- Address testing of communication and connectivity between the entity and third-party service providers.
- Detail participation with critical third-party service providers to confirm that entity personnel understand integration with recovery processes.

VII.C Exercise and Test Strategies

Management should develop exercise and testing strategies that demonstrate the entity's ability to support connectivity, functionality, volume, and capacity using alternate facilities. The strategies should include expectations for individual business lines and use of exercise and testing methodologies and scenarios. Testing strategies should encompass internal and external dependencies, including activities outsourced to domestic and foreign-based third-party service providers. Management should test all aspects of the entity's BCP. Strategies may include:

- A multi-year plan to execute the specific depth and breadth of exercises and tests to identify gaps in the program by using different methodologies and scenarios over time.
- Expectations for testing internal and external recovery dependencies.
- Assumptions, methodologies, and exercises used to develop the test strategies.

Lessons learned from natural disasters and other events show that for critical business functions, testing strategies should include transaction processing and functional testing to assess the recoverability of infrastructure, capacity, and data integrity. Regardless of the recovery strategy used, management should regularly test recovery provisions commensurate with the risk to the entity and, where applicable, the overall financial service sector.

VII.D Exercise and Test Objectives

The exercise and testing objectives should include resilience, system monitoring, and the recovery of business processes and critical system components. Tests can range from recovering a single file to a full-scale failover to another data center. Tests should include physical security, critical systems, multiple departments, and third-party relationships. Exercises should be sufficiently thorough to test dependencies and interrelationships among systems and third-party service providers. As the exercise and test process matures, it should become increasingly complex up to and including full-scale recovery exercises. Exercises and any associated tests should accomplish the following objectives:

- Build confidence that resilience and recovery strategies meet business requirements.
- Demonstrate that critical services can be recovered within agreed upon recovery objectives (RTOs and RPOs), including customer SLAs, and within MTDs.
- Establish that critical services can be restored in the event of an incident at the recovery location.
- Familiarize staff with recovery processes.
- Verify that personnel are adequately trained and knowledgeable of recovery plans and procedures.
- Confirm exercise and test plans remain compatible with the BCP and the entity's infrastructure.
- Identify gaps and deficiencies.

VII.E Exercise and Test Plans

Plans address the objectives and expectations of the exercise or test and outline the scenario and any assumptions or constraints that may exist. Exercises and test plans should include metrics to assess whether objectives are met. Plans should identify roles and responsibilities for participants, support personnel, and observers.⁴⁰ Exercise and test plans should be commensurate with the nature, scale, and complexity of the recovery objectives.

Management should receive and review third-party service provider exercise results, regardless of the entity's extent of participation. Management should consider the scope and results of these exercises in the entity's BCP. Management should evaluate third-party service providers' resilience and ability to recover critical services used by the entity if an event occurs. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for additional information.

Test plans generally include the following:

- Roles and responsibilities for all test participants, including support personnel.
- A consolidated exercise and test schedule that encompasses all objectives.
- A specific description of objectives and methods.
- Identification of decision makers and succession plans.

⁴⁰ For the purposes of this booklet, the term "observers" does not constitute an independent review or audit function.

- Exercise and test locations.
- Exercise and test escalation procedures and the ability to adjust for simulated scenarios.
- Contact information.
- Metrics to measure the success or failure of the exercise or test.

Management should review the exercise and test results, update the BCP where appropriate, and report the results to the board or board-designated committee. Suggestions for improving test scenarios, plans, or scripts provided by test participants should be incorporated into the testing cycle, where appropriate.

VII.F Exercise and Test Scenarios

Management should develop realistic exercise and test scenarios, based on risks, which simulate disruptions in business functions and help management determine the ability to meet both business requirements and customer expectations. The goal should not be to execute “perfect” exercises without issues; instead, it should be to continuously strengthen the business continuity program and validate the BCP(s). Management should identify and document assumptions used in developing each scenario. The scenarios should include threats that could affect third-party service providers and others, such as significant business partners. Exercises and tests should include communication processes with applicable stakeholders. Exercises demonstrate not only the ability to failover to an alternate site but also validate recovery objectives. Management should consider all reasonably foreseeable risks to connectivity and service-level agreements between the entity’s facility(ies), third-party service provider facilities, and with any applicable counterparties (i.e., entities on the other side of a financial transaction) with whom they transact significant or critical business.

Scenarios may include:

- Simultaneous attacks affecting both the entity and a third-party service provider.
- Cyber-related events (e.g., isolated malware attack, DDoS attack, data corruption, or a full-scale data center outage).
- Use of mirrored sites to demonstrate that alternate sites can effectively support customer-specific requirements, work volumes, and site-specific business processes.
- Processing a full day’s work at peak volumes.

To the extent possible, scenarios should include only resources that would be available during an event (e.g., backup files or equipment at the alternate site). Considering data and systems helps management verify the integrity of data backups (including access to encrypted data) and the adequacy of off-site systems and supplies, such as workstations and procedure manuals.

Management should develop exercise and test scripts to guide participants and meet objectives. Each script should document the procedures, which may include:

- Applications, business processes, systems, or facilities reviewed.
- Sequential steps for employees or external parties to perform.

- Procedures to guide manual work-around processes.
- A detailed schedule for completion.
- Methods for participants to record results, quantifiable metrics, and any issues.

VII.G Exercise and Test Methods

Exercises and tests help management validate continuity and resilience of technology components, including systems, networks, applications, and data, that support critical business functions. The type or combination of methods should be determined by the entity's size and complexity and the nature of its business. The DHS offers assistance and examples of testing methods,⁴¹ which are available to all entities and may be helpful when developing exercises and tests. Rigorous exercise methods and increased frequency help provide greater confidence in the continuity and resilience of business functions. While comprehensive exercises involve greater investments of time, resources, and coordination, the benefit is a more accurate assessment of recovery capabilities if a disaster occurs. This assists management in assessing the resilience of systems and responsiveness of the individuals involved in the recovery process. Comprehensive testing of all critical functions and applications allows management to identify potential problems; therefore, management should use one of the more thorough testing methods discussed in this section to verify the BCP's viability.

While names for exercises and tests may be different, or used interchangeably, this booklet lists the most commonly encountered elements in the following subsections.

VII.G.1 Full-Scale Exercise

Full-scale exercises (sometimes called a full interruption or comprehensive exercise) help management validate internal and external interdependencies between critical business functions, information systems, and networks (e.g., for critical functions, exercises should include transaction processing and functional testing). Integrated exercises move beyond comprehensive exercises to include testing with internal and external parties and the supporting systems, processes, and resources. Management should periodically reassess and update exercise and test plans to reflect changes in the business and operating environment.

A full-scale exercise simulates full use of available resources (personnel and systems) prompting a full recovery of business processes. The goal of a full-scale exercise is to determine whether all critical systems can be recovered at the alternate processing site and whether personnel can implement the procedures defined in the BCP. For example, a full-recovery exercise might simulate the complete loss of primary facilities. Features of a full-scale exercise may include the following:

⁴¹ As members of an established sector of critical infrastructure, financial institutions can leverage testing constructs implemented by the DHS. The Homeland Security Exercise and Evaluation Program is the DHS policy and guidance for designing, developing, conducting, and evaluating exercises. The program provides a threat- and performance-based exercise process that includes a mix and range of exercise activities through a series of four reference manuals to establish exercise programs and design, develop, conduct, and evaluate exercises.

- Engaging personnel from all business units to participate and interact with internal and external management response teams.
- Validating the crisis or emergency management process is operating as designed.
- Verifying personnel knowledge and skills.
- Validating management response and decision-making capability.
- Coordinating participants and decision makers.
- Validating communication protocols.
- Conducting activities at alternate locations or facilities.
- Processing data using backup media or alternative methods.
- Completing actual transactional volumes or an illustrative subset.
- Performing recovery exercises over a sufficient length of time to allow issues to unfold as they would in a crisis.

VII.G.2 Limited-Scale Exercise

A limited-scale exercise is a simulation involving applicable resources (personnel and systems) to recover targeted business processes. The goal of a limited-scale exercise is to determine whether targeted systems can be recovered and whether personnel understand their responsibilities as defined in the plan. Features of a limited-scale exercise may include the following:

- Implementing a plan appropriate to the scenario.
- Verifying personnel knowledge and skills.
- Validating management response and decision-making capability.
- Executing on-the-scene coordination and decision-making roles.
- Verifying whether participants can connect to alternate system(s).
- Conducting activities at alternate locations or facilities.
- Testing communication and remote access capability (e.g., switching to alternate equipment or telecommuting).

While limited-scope exercises are important, they often have limited participation (e.g., departmental personnel only) or scope and do not necessarily allow management to gauge interconnectivity and how systems and capacity would support daily activities and workloads.

VII.G.3 Tabletop Exercise

A tabletop exercise (sometimes referred to as a walk-through) is a discussion during which personnel review their BCP-defined roles and discuss their responses during an adverse event simulation. The goal of a tabletop exercise is to determine whether targeted plans and procedures are reasonable, personnel understand their responsibilities, and different departmental or business unit plans are compatible with each other. By themselves, tabletop exercises are likely insufficient to validate recovery capabilities, because they are limited to a discussion-based analysis of policies and procedures.

Features of a tabletop exercise may include the following:

- Engaging operational and support personnel who are responsible for implementing the BCP.
- Practicing and validating specific functional response capabilities.
- Demonstrating knowledge, skills, team interaction, and decision-making capabilities.
- Role playing with simulated responses, critical steps, recognizing difficulties, and resolving problems.
- Clarifying critical plan elements, as well as problems noted during exercises.
- Creating action plans to correct issues.

VII.G.4 Tests

Management uses tests to verify the quantifiable performance and reliability of system resilience. The goal of testing is to determine whether system resilience conforms to the BCP and stated recovery objectives. Test methodologies and frequencies should align with the risk associated with the business function as well as the entity's testing strategies and objectives. Management should clearly define the characteristics of a successful test, which may include the following:

- Validating RPOs, RTOs, and MTDs.
- Demonstrating recoverability at peak volumes.
- Confirming that systems can support critical business processes (e.g., transfer to alternate sites, increased workloads, manual workarounds, and communication).
- Integrating technologies that support critical business activities, including data replication, recovery, and off-site storage.
- Testing backup data to assess integrity and availability.
- Certifying facility controls (e.g., environmental, backup power, and physical security).
- Verifying workspace restoration (e.g., network connectivity and communications).

VII.H Industry Exercises and Resilience

Given the potential for and nature of widespread and systemic disruptive events, public and private sector groups⁴² conduct exercises with their members to verify resilience across the financial industry. These exercises simulate significant regional or industry-wide emergencies, and members are encouraged to use backup sites and test their recovery capabilities. In addition to financial institutions, these coordinated tests often include participation by third-party service providers and government agencies. There are several methods for entities of all sizes to participate, such as through third-party service provider user groups or industry initiatives. For example, industry initiatives include the U.S. Department of the Treasury's Hamilton Series (national and regional series) and the FS-ISAC's Cyber-Attack Against Payment Systems (CAPS). The results of these exercises are usually available to members of industry and regulatory groups, and summaries may be available to the public.

⁴² Public and private groups include the [FS-ISAC](#), [Financial Services Sector Coordinating Council \(FSSCC\)](#), [Financial Systemic Analysis & Resilience Center \(FSARC\)](#), [Financial and Banking Information Infrastructure Committee \(FBIIC\)](#), and some regional coalitions.

Examiners should understand that opportunities to participate in such exercises may be limited. The *Financial Sector Cyber Exercise Template*⁴³ is publicly available from the U.S. Department of the Treasury, and management can use it to help verify the entity's own response capabilities and evaluate how it would respond during similar situations. Additionally, the template and results may be used as resources to validate exercise and testing assumptions and scenarios.

VII.I Third-Party Service Provider Testing

Third-party service providers deliver critical services to many entities and should be included in the enterprise-wide exercise and testing program. The extent of inclusion in the entity's program should be based on the criticality of the third-party service provider and the business function. Management should obtain assurance that third-party service providers are resilient and have adequate infrastructure and personnel to restore critical services consistent with business and contractual requirements. The right to perform or participate in testing with third-party service providers should be included in the contract governing the entity's relationship with the third party.

Management should actively participate in the entity's third-party service providers' testing programs and should verify that testing strategies include likely significant disruptive events. Third-party service providers should be transparent about testing parameters and results because not all clients can participate in every testing activity (e.g., when there is a large client volume) and some exercises and tests may not be relevant to the services provided to a specific customer. Management should request and receive test results and reports, remediation action plans and status reports upon their completion, and related analysis or modeling. Management should track and resolve any issues identified during the exercise in a timely manner, according to the severity of the issues. Any test results that affect the entity should be presented to its board. In most instances, equating one entity's recovery experience with another's does not guarantee similar results; therefore, management should perform its own analysis. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for additional information.

VII.J Testing for Core and Significant Firms

Management at core and significant firms should develop verification strategies and execute exercise and testing activities to validate that the entity implemented sound recovery practices consistent with the entity's role in the industry. Additionally, management should consider the impact of an event at its entity on the entire financial sector. The elements discussed in the *Sound Practices Paper* supplement the agencies' respective policies and other guidance on business continuity planning. Entities not designated as core and significant firms may also consider guidance from the *Sound Practices Paper* as a model for enhancing their testing processes.

Identification of external interdependencies is important given the sector's reliance on core and significant firms. Internal testing activities should include systems that support critical market activities in which these firms are core or significant. Exercise and testing activities should confirm that such critical clearing and settlement activities could be recovered within RTOs.

⁴³ Refer to the U.S. Department of the Treasury's [Financial Sector Cyber Exercise Template](#).

Industry standard time frames are continually adjusted based on available technology, pertinent risks, and industry initiatives. Management should adjust its RTOs to be in line with industry standard time frames. Furthermore, management should design testing activities to demonstrate the ability to perform the following activities if a wide-scale disruption affects the accessibility of key personnel:

- Complete pending material payments and transactions.
- Access funding.
- Manage material open risk positions.
- Make related entries to books and records.
- Validate internal and external communication protocols.
- Ensure connectivity, functionality, and volume capacity.

Management should test with the relevant core firms from their alternate sites and meet testing standards the core firms establish specifically for significant firms and for participants more generally. Management at core and significant firms should perform testing to assess the effectiveness of their recovery strategies. Management is also encouraged, to the extent practical, to participate in pertinent market-wide and cross-market tests⁴⁴ that validate connectivity from alternate sites and include transaction, settlement, and payment processes.

Examination and supervisory activities may include evaluations of verification strategies and testing plans to assess whether core and significant firms, which are the focus of the *Sound Practices Paper*, have achieved the resilience to protect the financial system from a wide-scale disruption.

VII.K Post-Exercise and Post-Test Actions

Management should document issues identified during exercises and tests and create action plans with target dates for resolving issues. Exercise and test results should be analyzed and compared with the objectives and success criteria in the exercise and test plans, and reported to appropriate levels of management. For those items not remediated, management should document decisions to accept risks identified during the exercises.

Additionally, management should test corrective actions implemented as a result of a failed recovery objective or to address major issues encountered. Management may choose to retest during or before the next regularly scheduled exercise depending on an issue's severity. Business line management should update the BCP based on test results and adjust the BCM process, including the exercise and testing program. Finally, management should submit regular reports to the board on the exercise and testing activities and whether the BCP meets the entity's recovery and resilience objectives.

Exercise and test results may include the following documentation:

⁴⁴ Industry and cross-market tests are often conducted by associations such as the Securities Industry Association, Bond Market Association, and Futures Industry Association. These associations are mentioned for illustrative purposes only; this note is not an endorsement of any of these associations.

- Dates and locations.
- An executive summary comparing objectives and results.
- Material deviations from the plans, including whether intended participation was achieved.
- Problems identified and lessons learned.
- Assignment of responsibility for timely resolution of issues identified.

Management should periodically analyze results and issues to determine whether problems can be traced to a common source, such as inadequate change control procedures. Fixing the root cause of the problem may help resolve many underlying issues.

VIII Maintenance and Improvement

Because risks and technology often change, management should regularly review and update the business continuity program to reflect the current environment. Periodic reviews allow management to align the business continuity processes with business objectives. Management should use this information to prioritize and focus on system and process corrections and enhancements. Triggers that prompt maintenance and improvement of the business continuity program may include the following:

- Changes in enterprise strategies.
- New or reconfigured products, services, or infrastructure.
- Changes in products and services offered by third-party service providers.
- Deficiencies identified in third-party service provider business continuity processes.
- New legislation, regulatory requirements, or resilience practices.
- Results of operational metric analysis (e.g., key risk indications, key performance indicators).
- Early warning indicators that may identify potential continuity events, crises, or incidents (e.g., frequency and severity of storms, increased cyber attacks, or increases in customer service calls).
- Variances between budgeted and actual business continuity expenses.
- Results from exercises and tests, and lessons learned.
- Changes in the threat landscape (e.g., new capabilities, intent of threat actors).
- Recommendations (e.g., from audits, vulnerability assessments, and penetration tests).

To determine the extent of changes to the business continuity program, BCM program personnel should contact business unit managers regularly to assess the nature of any changes to the business, structure, systems, software, hardware, personnel, or facilities. Management at smaller, less complex entities may perform this function informally; however, the maintenance and improvement concepts remain valid for those entities.

The business continuity program should be reviewed for accuracy and completeness at periodic intervals. Likely areas⁴⁵ that should be adjusted within the BCP may include:

⁴⁵ The concept of business continuity program review elements aligns with NIST SP 800-34 Rev. 1, [Contingency Planning Guide for Federal Information Systems](#). While this document pertains to federal information systems, the principles are relevant for non-federal information systems.